

Decision support for the optimal allocation of security controls

He Zhang, Kaushal Chari, Manish Agrawal*

Muma College of Business, University of South Florida, Tampa, FL 33620, United States

ARTICLE INFO

Keywords:

Design and evaluation of IT infrastructure
Constrained optimization
Stochastic programming
Analytical modeling
Decision support system
Risk management
Security breaches
Security survey

ABSTRACT

We present constrained optimization models that could be used in a decision support system for configuring security solutions for an information systems infrastructure. We begin with a deterministic model that uses security breach probabilities as parameters. Since security breach data is not easily available, breach probabilities are often estimated via surveys, which could lead to estimation errors. To develop robust solutions in the presence of estimation errors, we then present a stochastic optimization model that handles uncertainties in breach probability estimations. Our model solutions incorporate quantifiable security risk and business impact as the models are detailed enough to capture various categories of security attacks, and different levels of security protection and loss values for data and applications. We demonstrate the utility of our models by proposing security solutions for a realistic IT infrastructure using breach probability estimates derived from surveys.

1. Introduction

Security breaches are now being reported almost routinely. Facebook just reported a security breach affecting 50 million users [16]. In March 2018, the City of Atlanta became a victim of a ransomware attack [3]. Other major security breach incidents include the data breach at Equifax that affected 147.9 million consumers [9]; the WannaCry ransomware outbreak that infected more than 230,000 computers in 150 countries in 2017 [5]; Yahoo breaches in 2016 affecting over a billion user accounts [33]; US Internal Revenue Service breach in 2017 compromising the data on approximately 100,000 taxpayers [26]; the breach at Home Depot, where credit card details were stolen using malware installed at cash registers [21]; the Target breach, affecting up to 70 million customers [34]; and the breach at JP Morgan Chase, where hackers accessed personal information of bank customers [13]. These breaches had negative consequences on victim companies. For example, Target estimated a cost of \$148 million to its shareholders due to the data breach [30].

The 2016 US State of Cybercrime Survey of over 400 US organizations co-sponsored by PricewaterhouseCoopers, CSO magazine, CERT Division of Software Engineering Institute, and the United States Secret Service [24] reveals some interesting statistics: 79% of respondents had detected a security incident in the most recent year and 76% of respondents were more concerned about cybersecurity threats in the current year compared to the previous year.

In response, organizations are increasing information security investments. Gartner estimates that global information security

investments will rise from \$80 billion in 2016 to \$93 billion in 2018 [12]. Notwithstanding these large investments, in the above US State of Cybercrime Survey, only 38% of respondents indicated prioritization of security investments based on risk and impact to business. This suggests that the majority of information security spending is not aligned with risks and impacts to business. Plausible reasons for this misalignment include: a) Lack of data to quantify cyber security risks (the Cybercrime survey reported that only 47% of organizations performed periodic risk assessments); b) Use of unscientific ad hoc approaches that do not take quantifiable risks into account while directing cybersecurity enhancing investments. Thus, while many organizations have been making large cybersecurity enhancing investments in response to various security threats as well as to comply with various regulations such as the Sarbanes-Oxley Act, they have been doing so mostly in the dark. The goal of this research is to address this limitation by developing highly granular risk-based models as components of a decision support system for planning optimal cybersecurity enhancing investments.

This issue has attracted research attention. Early studies determined optimal security investments by assuming certain functional forms and associated parameter values to model risk components [14,36]. Cavusoglu et al. (2005) [6] used a game theoretic approach to determine the value of controls, but assumed risk parameters to be known. While the above papers present elegant models, their utility is limited by the accuracy of risk parameter estimates or the applicability of functional forms used. They do not directly address the problem of allocating specific security controls.

* Corresponding author.

E-mail addresses: hezhang@usf.edu (H. Zhang), kchari@usf.edu (K. Chari), magrawal@usf.edu (M. Agrawal).

<https://doi.org/10.1016/j.dss.2018.10.001>

Received 10 May 2018; Received in revised form 2 October 2018; Accepted 3 October 2018

Available online 11 October 2018

0167-9236/ © 2018 Elsevier B.V. All rights reserved.

Research on determining the optimal allocation of security controls (also referred to as counter measures) is in the nascent stages. Sawik [29] proposed a mixed-integer programming model using a conditional value at risk approach for optimal selection of countermeasures, given a set of potential threats and a set of available controls. Rakes et al. [25] proposed an integer programming model for optimal allocation of counter measures for a given threat level profile. The approaches in both Sawik [29] and Rakes et al. [25] require enumerating all possible threats and estimating every counter measure's effectiveness against each of the threats. This is usually not very practical to implement. Yeo et al. [35] used a workflow based model for control assignment. However, all security attacks, their paths, as well as controls needed to counter these attacks need to be predetermined in order to use the workflow model. This may pose challenges in practice as attackers constantly discover new paths for security attacks.

Simulation based approaches available in the literature [10,20,32], typically use synthetic data to evaluate security measures. These papers do not directly address the problem of optimal allocation of controls for an IT infrastructure, given risk and cost data.

In the current security environment, there has been considerable interest in developing decision support systems (DSS) to assist managers in optimizing security controls. Rees et al. [27] propose a DSS for computing the uncertain risk faced by an organization under cyber-attack. El-Gayar and Fritz [11] present an architecture and design for a web-based multi-perspective decision support system and underlying multi-criteria decision framework for security decision making and planning. The DSS allows various stakeholders (e.g. IT and executives) to determine weights for different priorities at each stage of the decision-making process - asset identification, threat assessment and control selection. While useful, the granularity of the systems proposed in these papers needs to be improved for determining the optimum allocation of controls. Table 1 summarizes relevant work related to the allocation of security controls.

A challenge for the current research is that it is necessary to estimate breach probabilities to determine the optimal allocation of controls. Breach probabilities in the presence of controls are not easily available. Instead, many studies estimate parameters such as bypass rates or component failure rates from sources such as historical data observed over a period of time [1], or vulnerability and/or patch release data stored in public databases [22]. Typically, this data is either sparse or has a lot of noise, and cannot be used to accurately assess the security risks of any given IT infrastructure, especially when the data gathering environment does not match the specific environment or configuration of the IT infrastructure.

In this paper, we explicitly incorporate breach probability estimates

in an optimization model for allocating security controls in any given IT infrastructure with the goal of minimizing the sum of losses due to security breaches and the total cost of controls. Our model, which is highly granular, determines control allocations that are in alignment with risk and business impact. To account for the noise in model parameter estimates such as breach probabilities, we present a stochastic version of the optimization model that improves the robustness of the solutions by addressing uncertainties in breach probability estimates. This is a key contribution of this paper. The model is then applied to a realistic IT infrastructure, using probability estimates from a survey of security professionals. We conduct computational experiments to show how the model can be used to estimate optimal changes in security expenses. Finally, we present a high level DSS architecture for security planning based on our models.

This paper is organized as follows. In Section 2, we present optimization models for determining optimal allocation of security controls. In Section 3, we describe our approach for determining breach probabilities. We then present results from our computational experiments in Section 4. In Section 5, we present a high level DSS architecture for a system to support security planning. Conclusions are provided in Section 6. An appendix contains a description of the process used to determine a realistic IT configuration and collect breach data, as well as the procedure to compute security expenses.

2. Models for optimal allocation of controls

The allocation of controls is designed to prevent three types of security breaches described below.

2.1. Types of security breaches

The US Code Title 44, Chapter 35, Section 3542 [31] defines information security as protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide the following.

- (A) Integrity: guarding against improper information modification or destruction that ensures information non-repudiation and authenticity;
- (B) Confidentiality: preserving authorized restrictions on access and disclosure, including means for protecting personal privacy and proprietary information; and
- (C) Availability: ensuring timely and reliable access to and use of information.

Table 1
Relevant prior work.

Research	Description	Comments	Allocation of specific security controls
[14]	Analytical model to determine optimal information security investment	Determines the optimal investment in security, without identifying security controls	No
[36]	Optimal security investment for system-specific and general security measures	Determines the optimal investment in security, without identifying security controls	No
[6]	Game theoretic model to determine the value of intrusion detection systems	Assumes knowledge of the hacker's utility and costs of intrusion	No
[27]	Genetic algorithms and scenarios to select optimal set of controls	Assumes the availability of accurate estimates of control breach probabilities	Yes
[25]	An integer programming model for optimal allocation of counter measures for a given threat level profile	Requires enumerating all possible threats as well as assumes the availability of accurate estimates of every control's effectiveness against each of the threats	Yes
[29]	Mixed integer programming model for the optimal selection of security controls	Requires enumerating all possible threats as well as assumes the availability of accurate estimates of every control's effectiveness against each of the threats	Yes
[35]	Analytical model to determine optimal security control placement in business process workflow	Requires prior enumeration of all security incident patterns as inputs to a deterministic model	Yes
Current	Analytical models for the allocation of optimal set of security controls	Handles uncertainties in the estimates of threat survival in the presence of controls; does not require prior enumeration of all possible threats; explicitly models classes of breaches such as availability breaches	Yes

The models presented in Section 2.4 (deterministic) and Section 2.5 (stochastic) capture the losses associated with integrity, confidentiality and availability breaches.

An IT infrastructure typically consists of client machines, server hosts that run different server applications, storage devices to store databases, and a networking infrastructure to connect various devices. To increase availability or scalability, servers are replicated in server farms. Multiple types of transactions are typically initiated from client machines. To protect the IT infrastructure from integrity, confidentiality and availability breaches, various types of controls are used. These include perimeter routers, proxy servers and host specific controls such as host firewalls. Controls have overlapping coverages against security attacks, i.e., multiple controls can protect against some aspects of the same attack. The use of general controls such as perimeter routers, as well as host specific controls such as web server security modules and strong password policies, reduce the likelihood of breaches, but do not guarantee complete security. The failure probabilities of integrity, confidentiality and availability breaches depend on both the general controls as well as host specific controls. An optimal security control allocation model minimizes the costs of security controls and expected breach costs in the presence of these controls. The models developed in this paper account for these dependencies.

2.2. Notations

The notations used in our models are in Table 2.

2.3. Modeling overview

We make the following assumptions while developing our models. These assumptions make our models tractable with minimal loss of generality.

Assumption 1. All transaction types incur the same processing time at any host. Hence the processing capacity of computers is represented by the number of transactions per minute. This assumption can be easily relaxed by adding appropriate scaling factors based on actual transaction times of different transaction types, thereby making the model more detailed.

Assumption 2. For each node p , the breach probabilities $v_p^a([y_i]_{i \in G}, [z_{pj}]_{j \in S})$, $v_p^i([y_i]_{i \in G}, [z_{pj}]_{j \in S})$ and $v_p^c([y_i]_{i \in G}, [z_{pj}]_{j \in S})$ are convex piecewise linear functions with respect to security settings $[y_i]_{i \in G}$ and $[z_{pj}]_{j \in S}$. We later provide empirical evidence to support diminishing returns for security expenses.

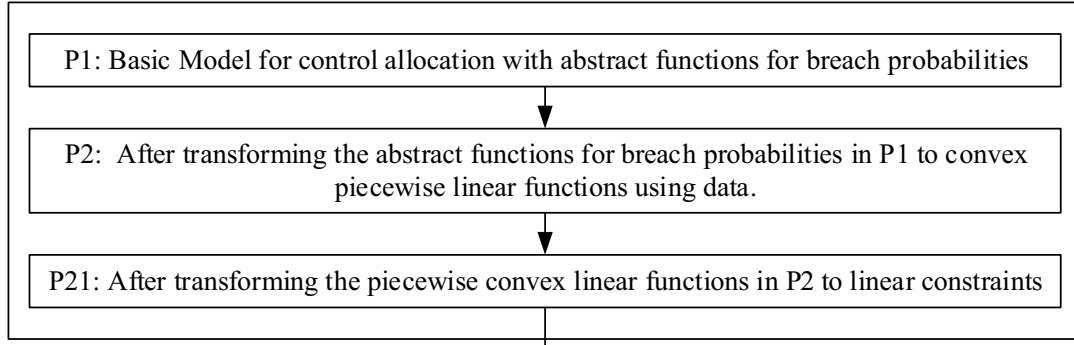
Assumption 3. The transaction rate function $g_f([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f})$ is separable with respect to the breach probability v_p^a , i.e., $g_f([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f})$

Table 2

Notations.

Sets	
T	Index set of transaction types
F	Index set of farms. A farm is a collection of computers running similar applications for load balancing and fault tolerance
F_t	Index set of farms used in processing transaction $t \in T$
N_f	Index set of nodes (i.e., computers) in farm $f \in F$
N	Index set of all nodes across various farms, i.e., $\cup_{f \in F} N_f$
G	Index set of general security setting types based on one or more controls such as a perimeter router
S	Index set of host specific security setting types based on one or more controls such as a host-specific firewall
Input parameters	
t^a	Average time to restore the system due to an availability breach
r_t^i	Desired transaction rate of transactions of type $t \in T$ (in transactions per minute); this rate is achieved when the processing capacities of servers are optimally realized
Q_p	Capacity of node p in transactions per minute
π_{tf}	Number of sub-transactions spawned from a single transaction of type $t \in T$ at farm $f \in F$
c_t^i	Unit cost of transaction loss rate of transaction type $t \in T$, due to an availability breach
c_i^g	Unit cost of general security setting of type $i \in G$
C_{pj}^s	Unit cost of host specific security setting of type $j \in S$ used at node p
l_p^i	Average loss amount when there is an integrity breach of files at node p
l_p^c	Average loss amount when there is a confidentiality breach of files at node p
γ	An input parameter that represents the processing capacity of a farm in transactions/min
$\alpha_{c,m}$, $\alpha_{i,m}$, and $\alpha_{a,m}$	are coefficients of expense terms in the m^{th} equations that are piecewise linear approximations of confidentiality, integrity and availability breach probabilities as functions of expense respectively
$\beta_{c,m}$, $\beta_{i,m}$, and $\beta_{a,m}$	are intercept terms in the m^{th} equations that are piecewise linear approximations of confidentiality, integrity and availability breach probabilities as functions of expense respectively
ε_c , ε_i , ε_a	are random errors for confidentiality, integrity and availability breach probability estimates respectively
ξ	is a vector of ε_c , ε_i , ε_a
k_c , k_i , and k_a	denote the number of piecewise linear approximation segments used for confidentiality, integrity and availability breach probabilities
Functions	
$v_p^a([y_i]_{i \in G}, [z_{pj}]_{j \in S})$	Probability of availability breach at node p , given p is shielded by controls $[y_i]_{i \in G}$ and $[z_{pj}]_{j \in S}$; For better readability v_p^a will be used without any parenthesis when necessary
$v_p^i([y_i]_{i \in G}, [z_{pj}]_{j \in S})$	Probability of integrity breach at node p , given p is shielded by controls $[y_i]_{i \in G}$ and $[z_{pj}]_{j \in S}$; For better readability v_p^i will be used without any parenthesis when necessary
$v_p^c([y_i]_{i \in G}, [z_{pj}]_{j \in S})$	Probability of confidentiality breach at node p , given p is shielded by controls $[y_i]_{i \in G}$ and $[z_{pj}]_{j \in S}$; For better readability v_p^c will be used without any parenthesis when necessary
$h_f^p(V_p^a, Q_p)$	is a convex and monotonically non-decreasing function of v_p^a and Q_p used for computing the expected decrease in the processing capacity of farm f due to availability breach at node p in f
$g_f([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f})$	is a function to compute the expected transaction rate at farm f , given vectors $[v_p^a]$ and $[Q_p]$ for the nodes in f
Variables	
r_t^i	Expected transaction rate of transactions of type $t \in T$ (in transactions per minute)
y_i	= 1 if general security setting of type $i \in G$ used in the IT infrastructure; 0 otherwise
z_{pj}	= 1 if host specific security setting of type $j \in S$ used at node p ; 0 otherwise
exp_p	is the total expense related to security controls shielding node p and is given by $\sum_{i \in G} c_i^g y_i + \sum_{j \in S} C_{pj}^s z_{pj}$
u_p^c and u_p^i	are variables that represent the estimate of confidentiality and integrity breach probabilities from the piecewise linear approximations of confidentiality and integrity breach probabilities respectively

Deterministic Model



Stochastic Model

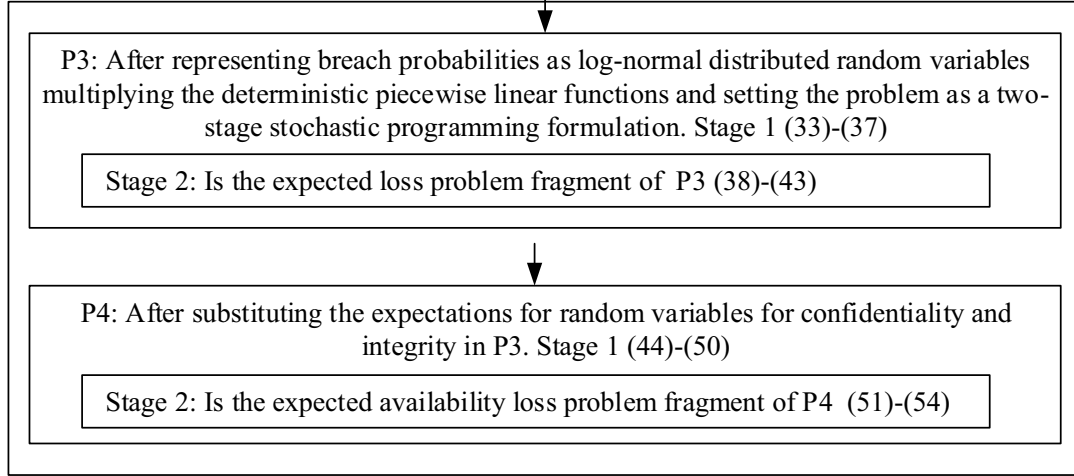


Fig. 1. Models and model transformations.

$$[Q_p]_{p \in N_f} = - \sum_{p \in N_f} h_f^p(v_p^a, Q_p) + \gamma.$$

$\forall p \in N_f$, given Q_p , the function $h_f^p(v_p^a, Q_p)$ is a convex and monotonically non-decreasing function with respect to v_p^a , and γ is a constant. Later, we show the detailed mapping of $h_f^p(v_p^a, Q_p)$ and γ for our computational example, where $h_f^p(v_p^a, Q_p)$ computes the magnitude of expected reduction in the transaction rates of nodes in farm f due to availability breaches and γ maps to the total installed processing capacity of the farm in terms of the total transaction rate. This provides a general method to model transaction rates as a monotonically non-increasing function of breach probabilities.

We now develop deterministic and stochastic models for security control allocation. Fig. 1 gives a high level overview of our models and model transformations developed in Sections 2.4 and 2.5.

2.4. Deterministic model

We start with a deterministic model for allocating controls that minimizes the cost of controls and losses due to successful breaches. An optimal assignment of controls can be obtained by solving the following deterministic model.

$$\begin{aligned} \text{Problem P1: } Z_1 = \min & \sum_{i \in T} c_i^l (r_i^d - r_i^e) t^a + \sum_{p \in N} l_p^c v_p^c ([y_i]_{i \in G}, [z_{pj}]_{j \in S}) \\ & + \sum_{p \in N} l_p^i v_p^i ([y_i]_{i \in G}, [z_{pj}]_{j \in S}) + \sum_{i \in G} c_i^g y_i + \sum_{p \in N} \sum_{j \in S} C_{pj}^s z_{pj} \end{aligned} \quad (1)$$

subject to

$$\sum_{i \in T} r_i^e \pi_{if} \leq g_f ([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f}) \quad \forall f \in F \quad (2)$$

$$r_i^e \leq r_i^d \quad \forall i \in T \quad (3)$$

$$\sum_{i \in G} y_i = 1 \quad (4)$$

$$\sum_{j \in S} z_{pj} = 1 \quad \forall p \in N \quad (5)$$

$$\begin{aligned} y_i \in \{0, 1\} \quad \forall i \in G; z_{pj} \in \{0, 1\} \quad \forall p \in N, j \in S; v_p^a, v_p^i, v_p^c \\ \geq 0 \quad \forall p \in N \quad r_i^e \geq 0 \quad \forall i \in T \end{aligned} \quad (6)$$

The objective Function (1) captures the tradeoffs between the losses due to security breaches and the cost of security settings consisting of one or more controls. These tradeoffs are enabled by the failure probabilities of breaches v_p^a , v_p^i , and v_p^c in the model, as they are determined by security expenses which in turn are determined by decision variables y_i and z_{pj} . The first three terms in the objective function denote losses due to availability, confidentiality and integrity breaches respectively. The last two terms denote the cost of general as well as host-specific security settings respectively. Constraint (2) requires that server farms have adequate capacity to handle the expected transaction rate needs. Constraint (3) dictates that the expected transaction rate be less than or equal to the desired transaction rate for transactions of that type. The expected transaction rate is based on availability considerations [15], and is determined by g_f , which is a function of the vectors of probabilities of failure due to availability breach v_p^a and transaction

processing capacities Q_p , for nodes in f . Constraint (4) requires that one general security setting be used, while constraint (5) requires that one security setting be used at any given host. A security setting refers to a specified combination of available controls. Note that the decision variables y_i and z_{pj} are binary integers. Security setting expenses are annualized and consist of depreciation and maintenance expenses. Breach probabilities v_p^c , v_p^i , v_p^a are obtained through empirically determined functions, while the desired transaction rate, $r_t^d \geq 0$ is exogenous to P1, and can be set to desired values that do not exceed the transaction processing capacity of a farm when availability breach probabilities are 0 as given by Constraint (7).

$$\sum_{t \in T} r_t^e \pi_{tf} \leq g_f([0]_{p \in N_f}, [Q_p]_{p \in N_f}) \quad \forall f \in F \quad (7)$$

When the model is solved, the optimal security setting, which is an assignment of controls (such as firewalls, packet filtering routers, etc.), is determined such that the total cost is minimized. Fig. 1 shows various model transformations.

In Problem P1 (1)–(6), the breach probabilities v_p^c , v_p^i and v_p^a are functions with respect to decision variables y_i , and z_{pj} . v_p^c , v_p^i and v_p^a are convex piecewise linear functions of total security expense for node p . Note there are k_c , k_i , and k_a piecewise linear functions for confidentiality, integrity and availability breaches respectively.

$$v_p^c = \max_{m=1, \dots, k_c} \{\alpha_{c,m} \exp_p + \beta_{c,m}\} \quad (8)$$

$$v_p^i = \max_{m=1, \dots, k_i} \{\alpha_{i,m} \exp_p + \beta_{i,m}\} \quad (9)$$

$$v_p^a = \max_{m=1, \dots, k_a} \{\alpha_{a,m} \exp_p + \beta_{a,m}\} \quad (10)$$

where $\exp_p$ is the total cost of the general and specific security setting shielding node p , which is determined by y_i , $i \in G$, z_{pj} , $j \in S$ as:

$$\exp_p = \sum_{i \in G} c_i^g y_i + \sum_{j \in S} C_{pj}^s z_{pj} \quad \forall p \in N \quad (11)$$

Per Assumption 2, the breach probabilities v_p^c , v_p^i and v_p^a can be modeled as non-increasing convex functions because of the diminishing returns. For computational modeling, we use piecewise linear convex functions to approximate these breach probabilities, since convex functions can be approximated to any accuracy by using piecewise linear convex functions. Based on Assumption 3 that assumes independence of availability breaches across nodes in a farm, we have

$$g_f([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f}) = - \sum_{p \in N_f} q(Q_p) v_p^a + \gamma \quad (12)$$

where $q(Q_p)$ is a function of Q_p and γ is a constant as specified previously. Note, $h^p(V_p^a, Q_p) = q(Q_p) v_p^a$. Recall from Section 2.3, $h^p(v_p^a, Q_p)$ denotes the expected transaction processing capacity that is lost due to availability breaches at node p of farm f , while γ denotes the installed transaction processing capacity of f . Thus the left hand side of Eq. (12) denotes the expected transaction rate of f and is based on the assumption that the availability breaches in the nodes of f are independent of each other.

After incorporating Eqs. (8)–(12) in P1, the problem transforms to P2.

$$\begin{aligned} \text{P2: } Z_2 = \min & \sum_{t \in T} c_t^l (r_t^d - r_t^e) t^a + \sum_{p \in N} l_p^c \max_{m=1, \dots, k_c} \{\alpha_{c,m} \exp_p + \beta_{c,m}\} \\ & + \sum_{p \in N} l_p^i \max_{m=1, \dots, k_i} \{\alpha_{i,m} \exp_p + \beta_{i,m}\} + \sum_{i \in G} c_i^g y_i + \sum_{p \in N} \sum_{j \in S} C_{pj}^s z_{pj} \end{aligned} \quad (13)$$

subject to

$$\exp_p = \sum_{i \in G} c_i^g y_i + \sum_{j \in S} C_{pj}^s z_{pj} \quad \forall p \in N \quad (14)$$

$$\sum_{t \in T} r_t^e \pi_{tf} \leq - \sum_{p \in N_f} q(Q_p) \max_{m=1, \dots, k_a} \{\alpha_{a,m} \exp_p + \beta_{a,m}\} + \gamma \quad \forall f \in F \quad (15)$$

$$r_t^e \leq r_t^d \quad \forall t \in T \quad (16)$$

$$\sum_{i \in G} y_i = 1 \quad (17)$$

$$\sum_{j \in S} z_{pj} = 1 \quad \forall p \in N \quad (18)$$

$$y_i \in \{0, 1\} \quad \forall i \in G; z_{pj} \in \{0, 1\} \quad \forall p \in N, j \in S; r_t^e \geq 0 \quad \forall p \in N \quad (19)$$

To transform P2 into a mixed linear integer programming problem in standard form, we apply standard techniques to transform nonlinear convex piecewise linear equations to linear constraints [2]. Thus, P2 can be rewritten as the following linear integer programming problem P21.

$$\begin{aligned} \text{P21: } Z_2 = & \sum_{t \in T} c_t^l (r_t^d - r_t^e) t^a + \sum_{p \in N} l_p^c u_p^c + \sum_{p \in N} l_p^i u_p^i + \sum_{i \in G} c_i^g y_i \\ & + \sum_{p \in N} \sum_{j \in S} C_{pj}^s z_{pj} \end{aligned} \quad (20)$$

subject to

$$u_p^c \geq \alpha_{c,m} \exp_p + \beta_{c,m}, \quad m = 1, \dots, k_c \quad (21)$$

$$u_p^i \geq \alpha_{i,m} \exp_p + \beta_{i,m}, \quad m = 1, \dots, k_i \quad (22)$$

$$\exp_p = \sum_{i \in G} c_i^g y_i + \sum_{j \in S} C_{pj}^s z_{pj} \quad \forall p \in N \quad (23)$$

$$\sum_{t \in T} r_t^e \pi_{tf} \leq - \sum_{p \in N_f} q(Q_p) (\alpha_{a,m_p} \exp_p + \beta_{a,m_p}) + \gamma, \quad \forall f \in F, m_p = 1, \dots, k_a \quad (24)$$

$$r_t^e \leq r_t^d \quad \forall t \in T \quad (25)$$

$$\sum_{i \in G} y_i = 1 \quad (26)$$

$$\sum_{j \in S} z_{pj} = 1 \quad \forall p \in N \quad (27)$$

$$y_i \in \{0, 1\} \quad \forall i \in G; z_{pj} \in \{0, 1\} \quad \forall p \in N, j \in S; r_t^e \geq 0 \quad \forall p \in N \quad (28)$$

P21 is a mixed linear integer programming problem that can be solved using a solver such as CPLEX.

2.5. Stochastic model with uncertainty in breach probability estimates

When there are uncertainties in breach probabilities, we can use a piecewise linear model to fit the survey data for breach probabilities as a function of control expenses. The uncertainty is modeled as a log-normal distributed random variable and the breach probabilities are modeled as the product of the random variable and the deterministic convex piecewise linear function in Eqs. (8)–(10). The following expressions can be used to fit estimated breach probabilities as a function of control expenses:

$$v_p^c = \varepsilon_c \cdot \max_{m=1, \dots, k_c} \{\alpha_{c,m} \exp_p + \beta_{c,m}\} \quad (29)$$

$$v_p^i = \varepsilon_i \cdot \max_{m=1, \dots, k_i} \{\alpha_{i,m} \exp_p + \beta_{i,m}\} \quad (30)$$

$$v_p^a = \varepsilon_a \cdot \max_{m=1, \dots, k_a} \{\alpha_{a,m} \exp_p + \beta_{a,m}\} \quad (31)$$

where the random errors ε_c , ε_i , ε_a are given as.

$$\ln(\varepsilon_c) \sim N(\mu_c, \sigma_c^2), \ln(\varepsilon_i) \sim N(\mu_i, \sigma_i^2), \ln(\varepsilon_a) \sim N(\mu_a, \sigma_a^2) \quad (32)$$

We use all other parameters from the deterministic model in the stochastic model. Consider the decision variables: r_t^e , y_i , $i \in G$, and z_{pj} ,

$p \in N, j \in S$. The variables representing general and host-specific control settings y_i and z_{pj} now have to be determined based on uncertain breach probabilities. However, the expected transaction rate of transaction of type t , r_t^e , depends on the actual value of the breach probability v_p^e . To incorporate this, the control allocation model can be written as a two-stage stochastic programming problem as follows:

Stage 1:

$$P3: Z_3 = \min_{y_i, z_{pj}} \sum_{i \in G} c_i^g y_i + \sum_{p \in N} \sum_{j \in S} C_{pj}^s z_{pj} + E_\xi[U(\mathbf{exp}, \xi)] \quad (33)$$

subject to

$$\mathbf{exp}_p = \sum_{i \in G} c_i^g y_i + \sum_{j \in S} C_{pj}^s z_{pj} \quad \forall p \in N \quad (34)$$

$$\sum_{i \in G} y_i = 1 \quad (35)$$

$$\sum_{j \in S} z_{pj} = 1 \quad \forall p \in N \quad (36)$$

$$y_i \in \{0, 1\} \quad \forall i \in G; z_{pj} \in \{0, 1\} \quad \forall p \in N, j \in S \quad (37)$$

where $\mathbf{exp}$ is the vector of security control expenses associated with all the nodes and is given by $(\mathbf{exp}_p)_{p \in N}$, ξ is the random error vector and is given by $(\varepsilon_c, \varepsilon_b, \varepsilon_a)^T$, $U(\mathbf{exp}, \xi)$ is the business loss when control expense $\mathbf{exp}$ is used optimally, $E_\xi[U(\mathbf{exp}, \xi)]$ is the expectation of $U(\mathbf{exp}, \xi)$ with respect to ξ . We compute $U(\mathbf{exp}, \xi)$ as the optimal value of the Stage 2 problem as follows:

Stage 2:

$$U(\mathbf{exp}, \xi) = \min_{r_t^e} \sum_{t \in T} c_t^l (r_t^d - r_t^e) t^a + \sum_{p \in N} l_p^c \varepsilon_c u_p^c + \sum_{p \in N} l_p^i \varepsilon_i u_p^i \quad (38)$$

subject to:

$$u_p^c \geq \alpha_{c,m} \mathbf{exp}_p + \beta_{c,m}, m = 1, \dots, k_c \quad (39)$$

$$u_p^i \geq \alpha_{i,m} \mathbf{exp}_p + \beta_{i,m}, m = 1, \dots, k_i \quad (40)$$

$$\sum_{t \in T} r_{t\xi}^e \pi_{t\xi} \leq - \sum_{p \in N_f} q(Qp) \varepsilon_a (\alpha_{a,m_p} \mathbf{exp}_p + \beta_{a,m_p}) + \gamma \quad \forall f \in F, m_p = 1, \dots, k_a \quad \forall p \quad (41)$$

$$r_{t\xi}^e \leq r_t^d \quad \forall t \in T \quad (42)$$

$$r_{t\xi}^e \geq 0 \quad \forall t \in T \quad (43)$$

Note that the second stage optimal objective value $U(\mathbf{exp}, \xi)$ depends on both $\mathbf{exp}$ and the random error vector ξ . Problem (33)–(43) follows a standard two-stage stochastic programming framework in which the first-stage decision variables y and z only depend on the expectation, while the second stage variable r_t^e depends on the actual scenario of ξ . Since ε_c and ε_i only appear in the objective function $U(\mathbf{exp}, \xi)$ of the second-stage problem and not in the constraints, therefore the random variables ε_c , ε_b and ε_a are separable and easy to solve. Thus, the above model can be written as P4:

$$P4: Z_4 = \min_{y_i, z_{pj}} \sum_{i \in G} c_i^g y_i + \sum_{p \in N} \sum_{j \in S} C_{pj}^s z_{pj} + \sum_{p \in N} l_p^c E[\varepsilon_c] u_p^c + \sum_{p \in N} l_p^i E[\varepsilon_i] u_p^i + E_\xi[V(\mathbf{exp}, \xi)] \quad (44)$$

subject to

$$u_p^c \geq \alpha_{c,m} \mathbf{exp}_p + \beta_{c,m}, m = 1, \dots, k_c \quad (45)$$

$$u_p^i \geq \alpha_{i,m} \mathbf{exp}_p + \beta_{i,m}, m = 1, \dots, k_i \quad (46)$$

$$\mathbf{exp}_p = \sum_{i \in G} c_i^g y_i + \sum_{j \in S} C_{pj}^s z_{pj} \quad \forall p \in N \quad (47)$$

$$\sum_{i \in G} y_i = 1 \quad (48)$$

$$\sum_{j \in S} z_{pj} = 1 \quad \forall p \in N \quad (49)$$

$$y_i \in \{0, 1\} \quad \forall i \in G; z_{pj} \in \{0, 1\} \quad \forall p \in N, j \in S \quad (50)$$

where $\mathbf{exp} = (\mathbf{exp}_p)_{p \in N}$, $\xi = (\varepsilon_c, \varepsilon_b, \varepsilon_a)^T$ and $V(\mathbf{exp}, \xi)$ is the optimal value of the Stage 2 problem.

$$V(\mathbf{exp}, \xi) = \min_{r_t^e} \sum_{t \in T} c_t^l (r_t^d - r_t^e) t^a \quad (51)$$

subject to

$$\sum_{t \in T} r_{t\xi}^e \pi_{t\xi} \leq - \sum_{p \in N_f} q(Qp) \varepsilon_a (\alpha_{a,m_p} \mathbf{exp}_p + \beta_{a,m_p}) + \gamma, \quad \forall f \in F, m_p = 1, \dots, k_a \quad \forall p \quad (52)$$

$$r_{t\xi}^e \leq r_t^d \quad \forall t \in T \quad (53)$$

$$r_{t\xi}^e \geq 0 \quad \forall t \in T \quad (54)$$

Fig. 2 displays the flowchart for solving problem P4.

The two stage stochastic optimization problem P4 can be solved with the sample average approximation (SAA) method [28]. Initially, we plug the expectations of ε_i and ε_c in P4, obtained by taking means of respective distributions from the survey data. We then generate M random samples of ε_a according to its empirical distribution obtained from the data. The expectation in Eq. (44) is substituted by its sample average approximation. Phase 1 and all the Phase 2 problems (one for each instance out of M samples of ε_a) are combined as one single stochastic problem. This entails adding constraints (52)–(54) for each instance of the sample set to P4 (for a total of M instances), and replacing the last term in Eq. (44) with the sample average approximation, where $\sum_{t \in T} c_t^l (r_t^d - r_t^e) t^a$ is added to the approximation expression, once each for the M instances (see box 3 of Fig. 2). This extensive formulation is solved using a solver.

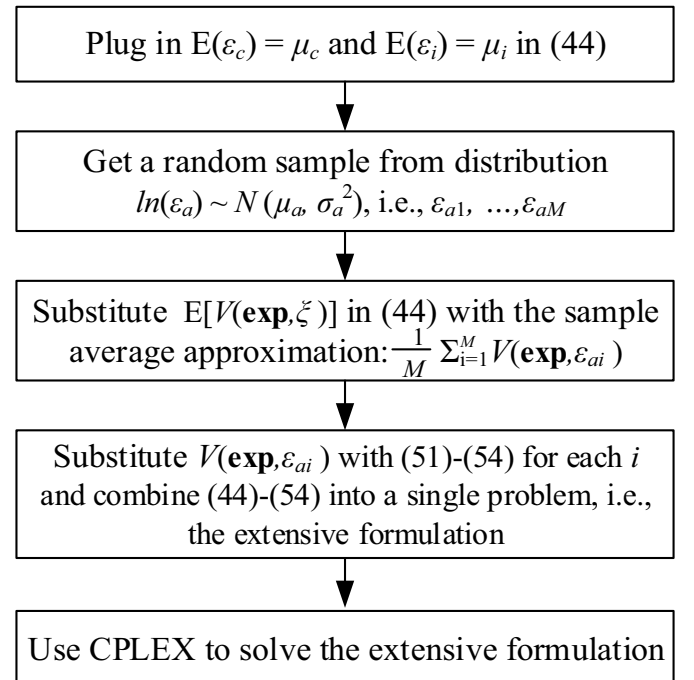


Fig. 2. Flow chart for solving P4.

3. Risk assessment

To calibrate as well as assess the usefulness of our models, we estimated breach probabilities as a function of security control expenses using a survey and cost data for a representative IT infrastructure in Fig. 3. This configuration was determined by a focus group of five IT security professionals, as being representative of a small to medium enterprise (SME) IT infrastructure for e-commerce. Details on the focus group can be found in Appendix A. The IT infrastructure consists of the following: 1) a web server farm containing two web servers (1, 2), 2) an application server farm containing two application servers (3, 4), and 3) a database farm consisting of two database servers (5, 6). Client machines on the internet initiate transactions that are sent to the web server farm. Based on load-balancing considerations, a transaction is routed to an appropriate web server in the farm. For illustration purposes, there are two transaction types as follows: 1) Type 1: This transaction is captured by a client and sent to any of the two web servers, where it is processed, and the results sent back to the client; 2) Type 2: This transaction captured by a client machine, is sent to any of the two web servers, where the transaction spawns a sub-transaction that is sent to one of the two application servers, where one database query is generated and sent to one of the database servers. The query result is then sent back from a database server to the application server, where additional business logic is executed and the result then sent to the web server, where further processing takes place, before results are sent back to the client. The two transaction flows are also illustrated in Fig. 3, where A, B, C, D, and E are placeholders for security controls. The following network-level (i.e., general) controls were identified by the focus group and used in various feasible combinations (see Table 3) in the survey: network firewall, network ACL, HSRP, application gateway, and IDS/IPS. The host-level controls used in various feasible combinations in the survey were: host firewall and SSL. A survey instrument was sent to security professionals in our network for our representative IT infrastructure. As per our request, the Information Systems Security Certification Consortium (ISC²), the organization that administers the CISSP certification also mailed the survey to current

holders of the CISSP certification. Survey respondents estimated breach probabilities for various combination of controls that were placed at placeholders A, B, C, D, and E in the example configuration shown in Fig. 3.

The following definition was included related to breach probability in the survey.

“Breach Probability: Proportion of attack incidences directed towards a host that are successful in causing a breach on that host. There are three breach probabilities - probability of confidentiality breach, probability of integrity breach and probability of availability breach. All breach probabilities are expressed as percentages.”

The definitions of confidentiality, integrity and available as stated in Section 2.1 were included in the survey. A total of 49 survey responses were obtained. The mean IT experience of the respondents was over 18 years, of which over 11 years were in information security, thereby indicating a high quality of the subject pool. For all feasible security control settings, security control expenses denoted by “expense” were estimated as described in Appendix A and shown in Table 3. The average breach probabilities across all subjects for each control setting are also shown in Table 3.

The summary statistics of the data collected are provided in Table 4.

We estimated a convex piecewise linear form for breach probabilities as a function of control expenses as given by Eqs. (8), (9) and (10). The number of segments used for the three cases was 2, i.e., $k_c = k_i = k_a = 2$ based on the visual inspection of data. The coefficients were then estimated by using standard least square methods. The estimates are given as:

$$\alpha_{c,1} = -0.7019, \beta_{c,1} = 48.4392, \alpha_{c,2} = -0.2638, \beta_{c,2} = 34.7189$$

$$\alpha_{i,1} = -0.8049, \beta_{i,1} = 49.8945, \alpha_{i,2} = -0.2645, \beta_{i,2} = 32.5634$$

$$\alpha_{a,1} = -0.7575, \beta_{a,1} = 49.0724, \alpha_{a,2} = -0.1656, \beta_{a,2} = 27.6976$$

Plots of average breach probabilities of survey data and estimated breach probabilities from the quadratic functions are shown in Fig. 4.

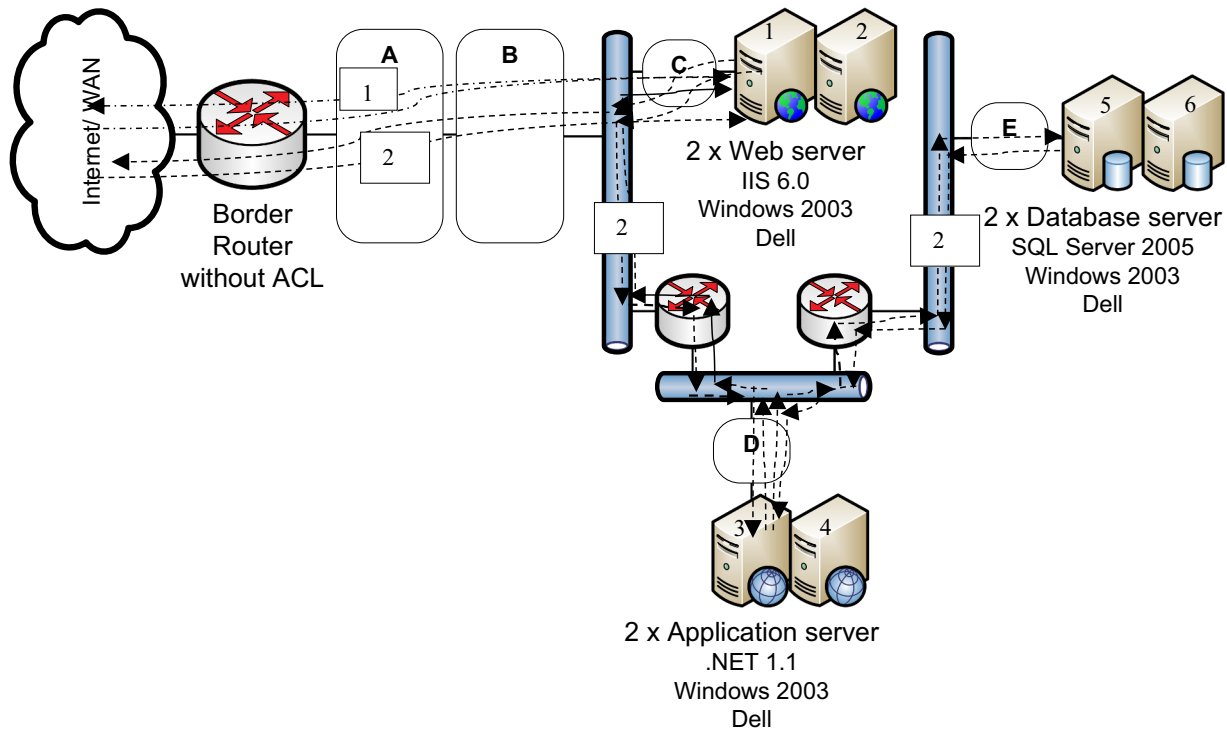


Fig. 3. Example configuration.

Table 3
Average breach probabilities and control expenses.

ID	Control combination	Expense	Average breach probability confidentiality (%)	Average breach probability integrity (%)	Average breach probability availability (%)
1	Network firewall + host firewall	\$21,314.00	33.92	32.66	32.9
2	Network firewall + application gateway	\$24,116.64	29.56	27.28	26.55
3	Network firewall + secure sockets layer (SSL)	\$16,086.73	31.63	31.92	32.39
4	Host firewalls + SSL	\$10,514.33	35.24	36	36.37
5	Network access control list (ACL) + SSL	\$6779.71	38.54	40.35	39.92
6	Hot standby router protocol (HSRP) + SSL	\$11,692.77	51.97	49.34	48.76
7	Application gateway + SSL	\$13,316.97	36.97	37.53	37.76
8	Intrusion detection system (IDS)/Intrusion prevention system (IPS) + SSL	\$22,922.77	34.45	34.21	34.29
9	Network firewall + host firewall + network ACL	\$25,450.18	27.21	24.16	24.32
10	Network firewall + host firewall + network ACL + HSRP	\$34,499.4	22.08	18.55	17.84
11	Network firewall + host firewall + application gateway + network ACL + HSRP + IDS/IPS	\$65,452.10	16.47	11.21	11.89
12	Network firewall + host firewall + application gateway + network ACL + HSRP + IDS/IPS + SSL	\$68,095.63	9.29	8.63	10.95

Table 4
Summary statistics.

	N	Mean	SD
Log (price)	588	9.93	0.68
Log (confidentiality)	575	2.96	1.19
Log (integrity)	577	2.88	1.29
Log (availability)	565	2.97	1.2

4. Computational experiments

The representative example presented in Fig. 3 was used as the context for the computational experiments. The overarching goal of the computational experiments was to demonstrate the utility of our optimization models. We executed the two models for the base case given by the following parameter values: $T = \{1, 2\}$; $F = \{1$ (web server), 2 (application server), 3 (database server); $F_1 = \{1, 2\}$, $F_2 = \{1, 2, 3\}$; $N_1 = \{1, 2\}$, $N_2 = \{3, 4\}$, $N_3 = \{5, 6\}$; $\pi_{11} = 1$; $\pi_{12} = 1$, $\pi_{13} = 0$, $\pi_{21} = 1$, $\pi_{22} = 1$, $\pi_{23} = 1$; $t^d = 20$; $G = \{1$ (no control), 2 (network firewall), 3 (network ACL), 4 (HSRP), 5 (application gateway), 6 (IDS/IPS), 7 (network firewall + application gateway), 8 (network firewall + network ACL), 9 (network firewall + network ACL + HSRP), 10 (network firewall + network ACL + HSRP + application gateway + IDS/IPS); $S = \{1$ (no control), 2 (host firewall), 3 (SSL), 4 (host firewall + SSL); $c_t^l = 100 \forall t$; $c_1^f = 0$; $c_2^f = 13,443.20$, $c_3^f = 4136.18$; $c_4^f = 9049.24$; $c_5^f = 10,673.4$; $c_6^f = 20,279.24$; $c_7^f = 24,116.64$; $c_8^f = 17,579.38$; $c_9^f = 26,628.52$; $c_{10}^f = 57,581.3$; $c_{p1}^s = 0$, $c_{p2}^s = 7870.80$, $c_{p3}^s = 2643.53$, $c_{p4}^s = 10,514.33 \forall p$; $l_p^b = l_p^c = 415,000 \forall p$; $Q_p = 30 \forall p$; $r_t^d = 30 \forall t$; The average annual losses due to security breaches of \$415,000 was used as reported in a recent study [23]. The various costs related to control settings were determined as outlined in Appendix A.

The capacities of the three farms were as follows:

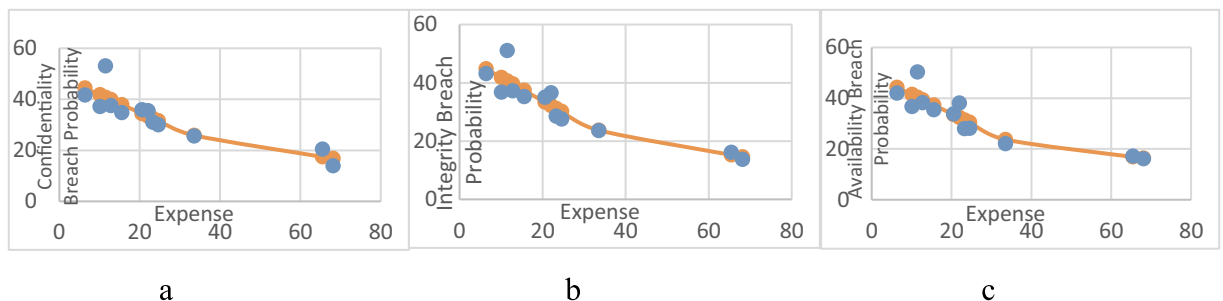


Fig. 4. Average and estimated confidentiality, integrity and availability breach probabilities.

Q_1^f (webserver farm) = $Q_1 + Q_2 = 60$ transactions/min

Q_2^f (application server farm) = $Q_3 + Q_4 = 60$ transactions/min

Q_3^f (database farm) = $Q_5 + Q_6 = 60$ transactions/min

The function $g_f([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f})$ for computing the expected transaction rate was computed as follows. For the database server farm, the following four states were possible for the two servers: (F, O), (O, F), (F, F), (O, O), where F is fail and O is OK state. The expected capacity of the webserver farm, which is dependent on the control assignments was given by $g_f([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f}) = v_1^a * (1 - v_2^a) * Q_2 + (1 - v_1^a) * v_2^a * Q_1 + v_1^a * v_2^a * 0 + (1 - v_1^a) * (1 - v_2^a) * (Q_1 + Q_2)$, where v_1^a and v_2^a were the availability breach probabilities of the two webserver farms. It can be easily verified that $q(Q_p) = Q_p$ and $\gamma = \sum_{p \in N_f} Q_p$.

Therefore $g_f([v_p^a]_{p \in N_f}, [Q_p]_{p \in N_f}) = \sum_{p \in N_f} Q_p v_p^a + \sum_{p \in N_f} Q_p$.

The following equations were applied to the survey data in estimating the distribution of multiplicative errors ϵ_c , ϵ_b and ϵ_a .

$$\ln(v_p^c) = \ln(\max_{m=1, \dots, kc} \{\alpha_{c,m} \exp_p + \beta_{c,m}\}) + \ln(\epsilon_c) \quad (55)$$

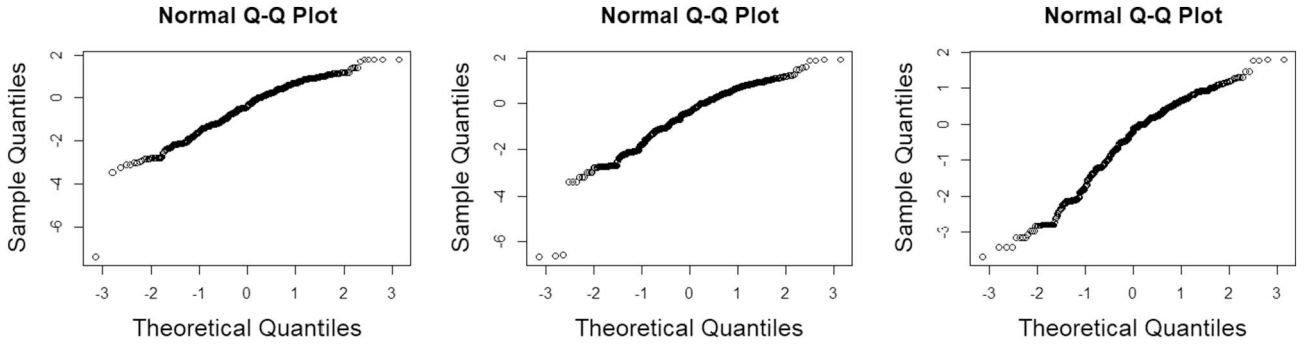
$$\ln(v_p^i) = \ln(\max_{m=1, \dots, ki} \{\alpha_{i,m} \exp_p + \beta_{i,m}\}) + \ln(\epsilon_i) \quad (56)$$

$$\ln(v_p^a) = \ln(\max_{m=1, \dots, ka} \{\alpha_{a,m} \exp_p + \beta_{a,m}\}) + \ln(\epsilon_a) \quad (57)$$

The normal Q-Q plots of $\ln(\epsilon_c)$, $\ln(\epsilon_i)$, and $\ln(\epsilon_a)$ are shown in Fig. 5a–c.

We examined the Q-Q plots to evaluate the distribution and approximated the distributions of $\ln(\epsilon_c)$, $\ln(\epsilon_i)$, and $\ln(\epsilon_a)$ as $\ln(\epsilon_c) \sim N(-0.4869, 1.1072^2)$, $\ln(\epsilon_i) \sim N(-0.5210, 1.1880^2)$, $\ln(\epsilon_a) \sim N(-0.4507, 1.1116^2)$. Therefore, we had $E[\epsilon_c] = 1.1342$ and $E[\epsilon_i] = 1.2028$. We used $\ln(\epsilon_a) \sim N(-0.4507, 1.1116^2)$ and a sample size of 100 for the phase 2 problem.

The models were solved using CPLEX. The optimal solution for the deterministic problem P2 was: $y_1 = \dots = y_9 = 0$, $y_{10} = 1$, $z_{p1} = z_{p2} = z_{p3} = 0$, $z_{p4} = 1 \forall p \in N$, with expected transaction rates

Fig. 5. Normal Q-Q Plots for $\ln(\epsilon_c)$, $\ln(\epsilon_i)$, $\ln(\epsilon_a)$.

$r_1^e = 30$ and $r_2^e = 20.1474$. The solution translated to the following configuration:

- Location A: Network ACL + HSRP
- Location B: Network firewall + Application gateway + IDS/IPS
- Location C (On each host): Host firewall + SSL
- Location D (On each host): Host firewall + SSL
- Location E: (On each host): Host firewall + SSL

For the stochastic problem P4, with a sample size of 100, the optimal solution was: $y_1 = \dots = y_9 = 0$, $y_{10} = 1$, $z_{p1} = z_{p2} = z_{p3} = 0$, $z_{p4} = 1 \forall p \in N$. For each sample ξ , the corresponding expected transaction rates were $r_{1\xi}^e$ and $r_{2\xi}^e$. The empirical distributions of random variables $r_{1\xi}^e$ and $r_{2\xi}^e$ are shown in Fig. 6.

For the base case as represented by parameter values described above, both the deterministic model and the stochastic model generated the same security controls configuration. For the deterministic case, the expected transaction rate was: $r_1^e = 30$, $r_2^e = 20.1474$. However, when there were errors in breach probability estimations, the expected transaction rates followed long-tail distributions, which implied that the actual transaction rates that could be realized had much lower values, i.e., as low as 11 for r_1^e . It implied that errors in breach probabilities had significant impact on both the expected loss and transaction rates.

We then performed additional computational experiments to test the robustness of the two models. Results obtained by varying average loss amount due to integrity and confidentiality breach incidents (l_p^i and l_p^c), while keeping all parameters the same as in the base case (including loss due to availability) for the deterministic as well as stochastic models are shown in Table 5. It can be seen that when the loss from integrity and confidentiality security breaches was low, the optimal policy was not to invest in any security controls in the case of the deterministic model. However, because of availability breaches that could

lead to transaction rates as low as 11 (Fig. 6), the stochastic model assigned security controls when integrity and confidentiality losses were low. At the other extreme, when the loss from security breaches was very high, then the optimal policy was to fully protect the IT infrastructure with all available controls. We also report the Loss Avoidance Percentage (see Table 5). This is given by (Unprotected Cost – Optimal Cost Protected)/Unprotected Cost, expressed as a percentage. For the deterministic case, the Optimal Cost Protected is given by the optimal value of Eq. (20), while for the stochastic case, the Optimal Cost Protected is given by the optimal value of Eq. (44). The Unprotected Cost is the total cost when no controls are assigned. Table 5 shows that the level of protection increases as the average loss amounts for confidentiality and integrity breaches increase, causing the Loss Avoidance Percentage to increase. This suggests that greater benefits are derived with increased protection, as costs from breaches increase.

To verify the robustness of the stochastic approach to noise, we used 110%, 120%, 130%, 140%, 150% of the standard deviation of the log-normal distribution described in Eq. (32) to check for the effects of noise in the probability estimations. For all five values, the optimal control configurations do not change across all the loss values (l_p^i , l_p^c) in Table 5.

With regards to the run-time performance of our approach, the CPU time taken to solve a deterministic model instance was 0.0468 s, while the CPU time taken to solve a stochastic model instance was 0.9048 s on a machine with the following specs: Intel(R) Core(TM) i7-3770 CPU @ 3.40 GHz. We also solved larger problem instances. For a problem with 6 farms and 4 servers per farm, leading to 24 servers, and with 6 different transaction types, the CPU times on the same computation platform for deterministic model instances ranged from 0.0156 s to 0.608 s, and from 0.0377 s to 1.3884 s for the stochastic model. This

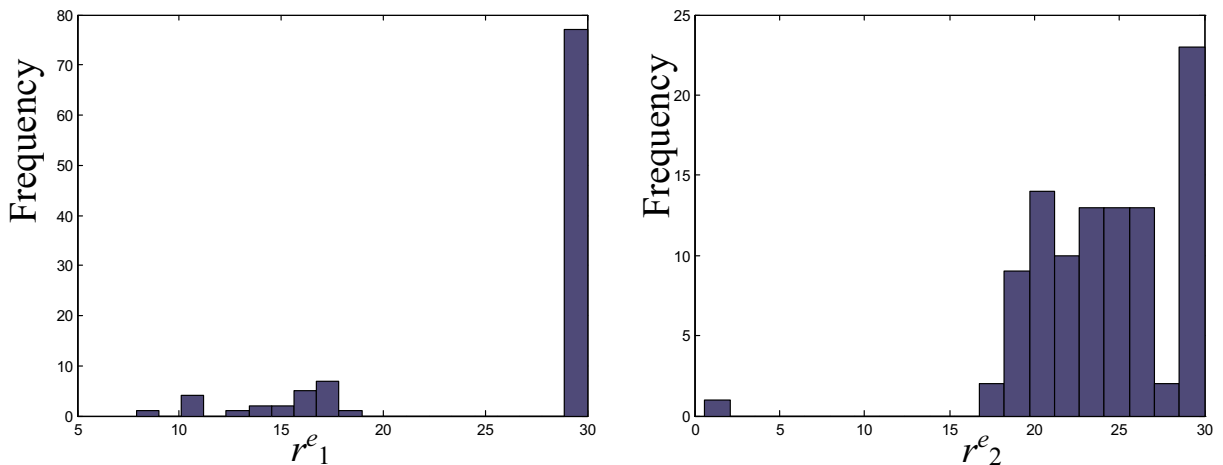
Fig. 6. Empirical distributions of r_1^e and r_2^e .

Table 5
Sensitivity analysis for both the deterministic and stochastic model.

Average confidentiality and integrity breach loss amounts (l_p, l_p)	Optimal control configuration (deterministic)	Optimal control configuration (stochastic)	Annual optimal expense (\$) (deterministic)	Annual optimal security expense (\$) (stochastic)	Loss avoidance percentage (deterministic)	Loss avoidance percentage (stochastic)
(100, 100)	General controls: none At every host: none $y_1 = 1, y_2 = \dots = y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	\$0	\$26,628.52	0%	0.95%
(1000, 1000)	General controls: none At every host: none $y_1 = 1, y_2 = \dots = y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	\$0	\$26,628.52	0%	4.36%
(10,000, 10,000)	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	\$26,628.52	\$26,628.52	18.33%	21.16%
(50,000, 50,000)	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	\$57,581.30	\$57,581.30	46.50%	48.80%
(100,000, 100,000)	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	\$57,581.30	\$57,581.30	53.85%	55.16%
(415,000, 415,000)	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	\$120,667.28	\$120,667.28	63.45%	64.22%
(500,000, 500,000)	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	General controls: network firewall + network ACL + HSRP At every host: none $y_1 = \dots = y_8 = 0, y_9 = 1, y_{10} = 0, z_{p1} = 1,$ $z_{p2} = z_{p3} = z_{p4} = 0, \forall p$	\$120,667.28	\$120,667.28	64.26%	64.91%

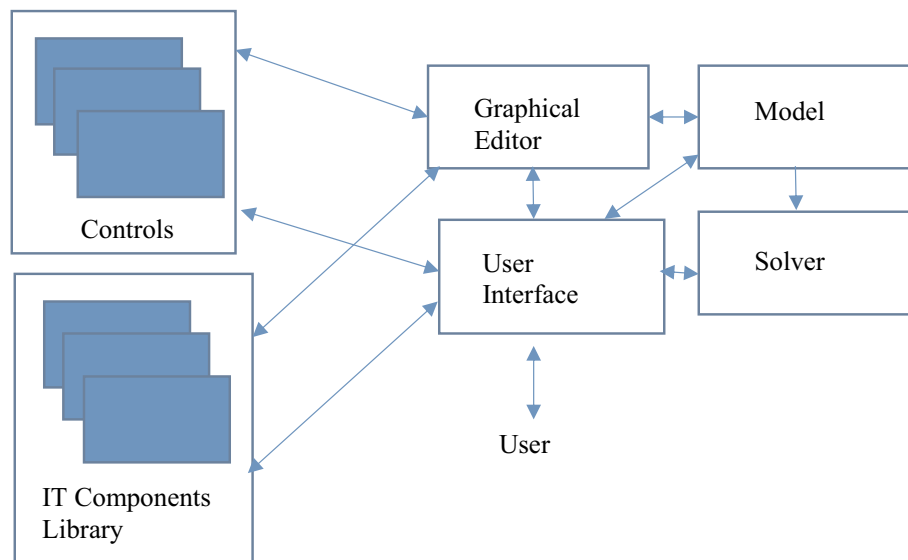


Fig. 7. Logical Architecture of DSS.

demonstrates the utility of our approach in solving larger problems.

5. DSS architecture

The DSS envisioned to support security planning is a tool that hides all the complexities of the optimization models that form the inner core of the DSS, while providing a user-friendly graphical user interface to enable non-technical users to easily interact with the system. The DSS is also envisioned to be a self-contained system that provides all the necessary functionality to support activities during the entire life-cycle of models such as model data collection, model instance creation, model execution, model solution, and model maintenance [18]. A high level logical architecture of the DSS for security planning is shown in Fig. 7.

The various components of the DSS are as follows:

Controls library: This is a repository of various security controls such as specific firewall components, various security software versions, router models, etc. Breach probabilities as well as costs associated with various controls are captured in the controls library. Since the blocking probabilities of controls are not additive due to overlapping coverages of controls, preconfigured control compositions representing various security settings are also stored along with their aggregate breach probabilities. The controls library could be accessed by a graphical user interface that enables users to treat controls as well as control compositions as high level objects that have properties.

IT components library: this is a repository of various common IT hardware and software platforms such as Windows 8 workstation, specific network switch models etc. Using the various components from this library, a user could configure the IT infrastructure in the DSS that mirrors the actual setup that the user is trying to protect.

Graphical editor: This component allows users to build an IT infrastructure by dropping and interconnecting component objects in a canvas. Component objects are drawn from the controls library and the IT components library. The editor can implement various composition rules to ensure that the IT infrastructure composed is valid. Research is available in the literature on building optimization models using graphical objects [7,17].

User interface: The user interface supports all the interactions between a user and the system during the various phases of the model life cycle. The various tasks supported include inputting controls and other IT components related data to the libraries, supporting user interactions with the graphical editor to create a model instance, invoking a solver

to execute a model instance, supporting user interactions to conduct sensitivity analysis of model solutions, and providing support for model instance revision or update. The user interface is graphical with drag and drop capabilities to enable users to compose an IT infrastructure graphically.

Model generator: This component takes the IT infrastructure configuration and converts it into a non-linear integer programming model instance in a format that can be executed by a solver such as CPLEX, LINGO, etc. An example of a model generator converting graphical models into solver executable model representation can be found in [8].

Solver: A solver such as CPLEX or LINGO generates an optimal allocation of controls by solving the model presented by the model generator.

6. Conclusions

We presented generalizable models for incorporating survey estimates on probabilities in determining optimal allocations for security controls to protect an information systems infrastructure. Our models are very general and can be customized for any specific IT environment, and to our knowledge, are the only models available in the information security risk literature that integrate risks associated with availability, confidentiality and integrity in allocating controls. Our first model, a deterministic optimization model for control selection can be applied when accurate estimates of breach probabilities are available. However, since, security breach data is not easily available, breach probabilities are often estimated via surveys, which could lead to estimation errors. To identify optimal allocations in the presence of these errors, we use a stochastic optimization model that handles uncertainties in breach probability estimations. To our knowledge, this is a key contribution to the literature.

To test our models, we collected security breach probability data estimates from a survey of IT/security professionals, and then using a least square error minimizing approach, determined piecewise linear functions that captured the relationships between security breach probabilities and security expenses. It should be noted that there are very few models available in the literature for control assignment that are grounded in real world data. This research attempted to overcome this limitation in the field by gathering empirical data from security experts for assessing risks.

We performed computational experiments to demonstrate the

robustness of our deterministic as well as stochastic models. As the average loss amount of security breaches decreased, the optimal security expenses also decreased. Finally, we presented a high level architecture for a DSS tool for security planning. This architecture enables the DSS to be used by non-technical users for security planning.

For the future, this research can be extended in many directions. First, a more granular model could be developed to capture differences in transaction times and differential loss values within each breach category. Second, efforts could be made in developing approaches that combine surveys and publicly available archival data to estimate breach probabilities with a high degree of accuracy. Third, efforts could be undertaken to build a prototype for decision support system for security planning based on the proposed architecture.

Acknowledgements

The authors thank the editor and the reviewers for their insightful comments that helped us improve the paper. The authors would also like to thank the participants of the focus group whose inputs helped in the creation of a practitioner survey, and to (ISC)² for distributing the survey to its membership.

Appendix A

A.1. Cost and probability estimates

We used a focus group to develop the reference configuration as well as identify controls for this research. We then used a survey of industry professionals to obtain estimates of breach probabilities.

A.2. Focus group

We followed the procedure recommended by Krueger and Casey [19] to conduct our focus group. Leadership contacts in the local offices of 7–8 large organizations with over 1000 employees, were requested to nominate a senior member of their IT security team to participate in the focus group. Five members participated in the focus group. Participants had self-rated work experience of 15–30 years, of which 9–15 years were in IT security. All but one focus group participant had the CISSP certification, and all participants had some information security related credentials. Participants represented finance, telecom, consulting and higher education sectors. The focus group lasted over 3 h.

A script was followed during the focus group. To initiate the discussion, participants listed the most important threats facing their respective organizations. The participants then architected a representative web application that could be used for the research, and identified the important controls for protecting it. The concept of common controls emerged during the discussion of security controls. Common controls were items such as training and patch management that affect all controls. In our survey, these were labeled as security best practices and respondents reported whether or not each of the best practices were assumed to be implemented. Finally, the focus group participants discussed a representative configuration including specific model numbers, for each security control identified by them.

Subsequent to the focus group, we obtained the price information for each security control from the vendor price lists for our academic institution. Annualized costs were obtained by adding hardware costs and annual maintenance costs. To obtain expected equipment lifetimes and annual personnel costs associated with hardware maintenance, we polled the focus group members a few days after the focus group meeting. Hardware costs were depreciated linearly over their expected lifetime to obtain estimates of annualized hardware costs for each control.

Maintenance costs were composed of personnel costs and hardware

maintenance agreement costs. Hardware maintenance agreements were a fixed 5% for all state institutions in our state and we used this statistic as our estimate of annual hardware maintenance costs. To obtain estimates of personnel costs associated with maintenance, we polled the focus group members for maintenance effort estimates associated with each control. Personnel salaries were obtained from the Bureau of Labor Statistics [4]. Multiplying salaries with mean estimates of annual efforts gave us the annual personnel costs associated with maintenance. These cost estimates have been included in our model.

A.3. Survey

Once the reference architecture and controls were identified by the focus group of experts, estimates of breach probabilities in the presence of different controls were obtained from a survey of industry professionals. These surveys were completed using two methods. We attended industry conferences within our local area and solicited responses from attendees. We also requested ISC² to mail the survey to the current holders of the CISSP certification. Through these efforts, 49 survey responses were obtained. We believe the low response rate is due to the length of the survey (approximately 30 min to complete). However, the responses were of high quality. The mean IT experience of the respondents was over 18 years, of which over 11 were in information security.

References

- [1] A. Arora, D. Hall, C.A. Pinto, D. Ramsey, R. Telang, Measuring the risk-based value of IT security solutions, *IEEE IT Professional* 6 (6) (2004) 35–42.
- [2] D. Bertsimas, J.N. Tsitsiklis, *Introduction to Linear Optimization* Athena Scientific, (1997).
- [3] A. Blinder, N. Perlroth, A Cyberattack Hobbles Atlanta, and Security Experts Shudder, *New York Times*, 2018, <https://www.nytimes.com/2018/03/27/us/cyberattack-atlanta-ransomware.html>.
- [4] BLS, Occupational Outlook Handbook: Network and Computer System Administrators, <http://www.bls.gov/ooh/Computer-and-Information-Technology/Network-and-computer-systems-administrators.htm>, (2015).
- [5] T.P. Bossert, It's Official: North Korea Is Behind WannaCry, *Wall Street Journal*, Dow Jones, New York, 2017 <https://www.wsj.com/articles/its-official-north-korea-is-behind-wannacry-1513642537>, Accessed date: August 2018.
- [6] H. Cavusoglu, B. Mishra, S. Raghunathan, The value of intrusion detection systems in information technology security architecture, *Inf. Syst. Res.* 16 (1) (2005) 28–46.
- [7] K. Chari, T.K. Sen, An integrated modeling system for structured modeling using model graphs, *INFORMS J. Comput.* 9 (4) (1997) 397–416.
- [8] K. Chari, T.K. Sen, An implementation of a graph-based modeling system for structured modeling (GBMS/SM), *Decis. Support. Syst.* 22 (2) (1998) 103–120.
- [9] N. Clements, Equifax's Enormous Data Breach Just Got Even Bigger, *Forbes*, 2018, <https://www.forbes.com/sites/nickclements/2018/03/05/equifaxs-enormous-data-breach-just-got-even-bigger/#5a1c6c9253bc>.
- [10] J.R. Conrad, Analyzing the Risks of Information Security Investments with Monte-Carlo Simulations, *Fourth Workshop on Economics of Information Security*, Boston, MA, 2005, p. 5.
- [11] O.F. El-Gayar, B.D. Fritz, A web-based multi-perspective decision support system for information security planning, *Decis. Support. Syst.* 50 (1) (2010) 43–54.
- [12] Gartner Research, Gartner Says Worldwide Information Security Spending Will Grow 7 Percent to Reach \$86.4 Billion in 2017, <https://www.gartner.com/newsroom/id/3784965>, (2018).
- [13] M. Goldstein, N. Perlroth, M. Corkery, Neglected Server Provided Entry for JPMorgan Hackers, *New York Times*, 2014.
- [14] L.A. Gordon, M.P. Loeb, The economics of information security investment, *ACM Trans. Inf. Syst. Secur.* 5 (4) (2002) 438–457.
- [15] B. Highleyman, P.J. Holenstein, B. Holenstein, Breaking the Availability Barrier: Survivable Systems for Enterprise Computing 1st Books Library, (2003).
- [16] M. Isaac, S. Frenkel, Facebook Security Breach Exposes Accounts of 50 Million Users, *The New York Times*, 2018.
- [17] C.V. Jones, An introduction to graph based modeling systems: part I. overview, *ORSA* 2 (2) (1990) 136–151.
- [18] R. Krishnan, K. Chari, Model management: survey, future research directions and a bibliography, *The Interactive Transactions of OR/MS* 3 (1) (2000).
- [19] R.A. Krueger, M.A. Casey, *Focus Groups: A Practical Guide for Applied Research*, Sage publications, 2008.
- [20] R.L. Kumar, S. Park, C. Subramaniam, Understanding the value of countermeasure portfolios in information systems security, *J. Manag. Inf. Syst.* 25 (2) (2008) 241–279.
- [21] K. Lobosco, Home Depot Hackers Stole 53 Million Emails, Too, <http://money.cnn>.

- com/2014/11/06/technology/security/home-depot-breach-emails/, (2014).
- [22] NIST, National Vulnerability Database, <http://nvd.nist.gov/>, (2008).
- [23] PwC, State of Cybercrime, (2014).
- [24] PwC, State of Cybercrime, <http://www.pwc.com/us/en/increasing-it-effectiveness/publications/assets/2015-us-cybercrime-survey.pdf>, (2015).
- [25] T.R. Rakes, J.K. Deane, L.P. Rees, IT security planning under uncertainty for high-impact events, *Omega* 40 (2012) 79–88.
- [26] A. Rapoport, Up to 100,000 Taxpayers Compromised in Fafsa Tool Breach, *I.R.S. Says*, *New York Times*, 2017.
- [27] L.P. Rees, J.K. Deane, T.R. Rakes, W.H. Baker, Decision support for cybersecurity risk planning, *Decis. Support. Syst.* 51 (3) (2011) 493–505.
- [28] A. Ruszczyński, A. Shapiro (Eds.), *Stochastic Programming. Handbooks in Operations Research and Management Science*, North-Holland, Amsterdam, 2003.
- [29] T. Sawik, Selection of optimal countermeasure portfolio in IT security planning, *Decis. Support. Syst.* 55 (1) (2013) 156–164.
- [30] S. Sharf, Target Shares Tumble as Retailer Reveals Cost of Data Breach, *Forbes*, 2014.
- [31] U.S. Code, U.S. Code, (2000), p. 44 <http://www.gpoaccess.gov/uscode/>.
- [32] J. Wang, A. Chaudhury, H.R. Rao, A value-at-risk approach to information security investment, *Inf. Syst. Res.* 19 (1) (2008) 106–120.
- [33] Yahoo, Yahoo Security Notice, <https://help.yahoo.com/kb/account/SLN27925.html?impressions=true>, (2016).
- [34] J.L. Yang, A. Jayakumar, Target Says Up to 70 Million More Customers Were Hit by December Data Breach, *The Washington Post*, 2014.
- [35] M.L. Yeo, E. Rolland, J.R. Ulmer, R.A. Patterson, Risk mitigation decisions for IT security, *ACM Transactions on Management Information Systems* 5 (1) (2014) 1–21.
- [36] W.T. Yue, M. Cakanyildirim, Y.U. Ryu, D. Liu, Network externalities, layered protection and IT security risk management, *Decis. Support. Syst.* 44 (2007) 1–16.



He Zhang is an assistant professor in the Information Systems and Decision Sciences department in the Muma College of Business at the University of South Florida. His research interests include healthcare information management, Big Data, and production and inventory management. Zhang's research has been published in journals including *Mathematical Programming* and he has presented his research at the International Conference on Stochastic Programming.



to 2010, and as the vice chair of the INFORMS Information Systems Society from 2007 to 2009. He is the co-winner of the 2009 Design Science Award from INFORMS Information Systems Society.



Manish Agrawal is a professor in the Information Systems and Decision Sciences department in the Muma College of Business at the University of South Florida. His research interests are in extreme event response, social media analytics, decision fusion, and software quality. His work has been published in *Decision Support Systems*, *Management Science*, *MIS Quarterly*, *INFORMS Journal on Computing*, *Journal of Management Information Systems*, *IEEE Transactions on Software Engineering*, and the *Journal of Organizational Computing and Electronic Commerce*. His research and teaching have been funded by the US National Science Foundation, and the US Department of Justice.